六、作业任务

任务 1：数据库与查询条件基础说明

1. 页面中的输入为什么会与数据库查询有关

页面的很多功能（比如商品搜索、用户登录、数据筛选）都需要从数据库获取数据才能正常展示。用户在页面输入的内容（如搜索关键词、账号密码），本质就是给数据库提供查询条件，系统会根据这个条件去数据库里精准匹配、提取对应数据，再返回给页面呈现。如果没有用户输入的条件，数据库就无法定位需要返回的数据，页面也就无法实现对应的功能。

2. 一个最小业务链路是什么

用户输入搜索关键词（输入条件），系统向数据库发送查询请求（数据库查询），数据库返回匹配的结果并在页面展示（返回结果）。

3. 用户输入是如何进入查询条件的

用户输入通过前端表单提交、接口请求传递到后端，后端程序将用户输入的内容，以拼接或参数化的方式整合到 SQL 查询语句中，使其成为查询条件的一部分，例如：SELECT * FROM table WHERE keyword = '用户输入内容'。

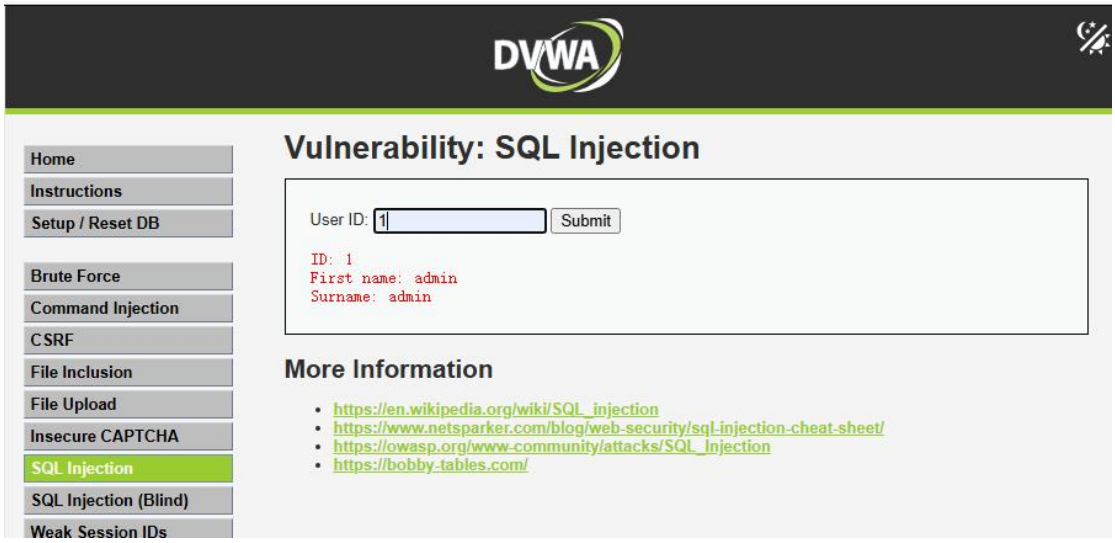
4.为什么这为 SQL 注入创造了可能性

若后端未对用户输入进行严格的校验、过滤或参数化处理，而是直接将用户输入拼接进 SQL 语句，恶意用户就可以构造特殊的 SQL 语句片段（如' OR 1=1 --）篡改原查询逻辑，绕过身份验证、窃取或修改数据，因此这种输入直接参与 SQL 拼接的机制为 SQL 注入创造了可能性。

任务 2：DVWA SQL Injection Low 现象记录

输入数字 1，页面仅返回 ID=1 的单个用户数据。

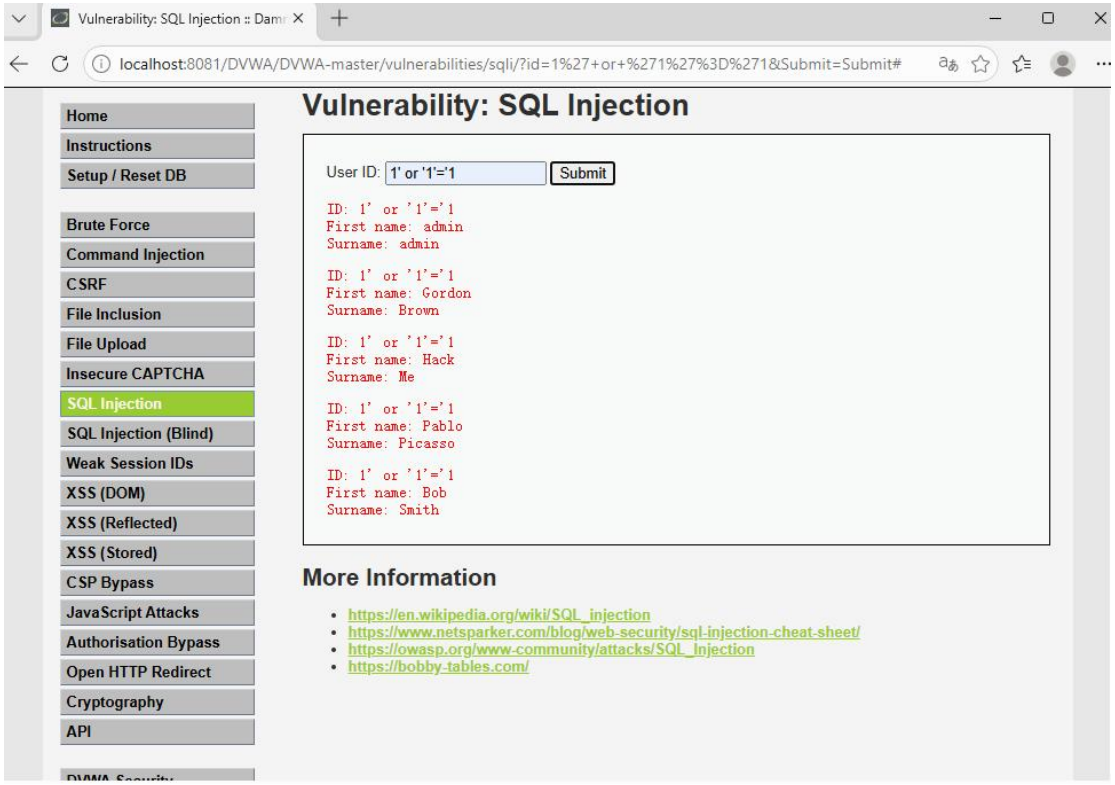
差异判断：说明正常场景下程序只会按指定 ID 精准查询单条数据，符合常规业务查询逻辑。



输入 1' 报错截图

输入单引号后，页面出现数据库 SQL 语法错误提示。

输入 1' or '1'='1，页面列出全部用户账号数据。
差异判断：说明查询条件被恶意篡改，永久成立的逻辑条件导致全表数据泄露，超出正常参数修改的合理范围。



为什么不像正常查询变化
正常修改 ID 参数，只会切换单条目标用户，不会出现语法报错、批量查全量数据的情况。当前异常现象是因为后端直接拼接用户输入，无过滤、无转义，可控字符篡改了 SQL 语句结构与查询条件，属于漏洞导致的非正常执行结果，并非业务正常查询的参数变化。
任务 3：机制分析与差异比较
1. 输入如何进入查询结构
用户在前端输入框提交自定义内容，后端未做过滤、转义与隔离处理，直接将用户输入字符串拼接嵌入原有 SQL 语句框架；数据库将拼接后的完整语句统一解析为合法 SQL 语法结构，识别关键字、闭合符号与查询条件，最终执行数据库操作；根据语句是否被篡改，页面产生正常数据回显、语法报错、全量数据泄露或页面状态异常等不同行为结果。
2. 为什么根因是“结构被污染”而不是“字符本身危险”
单引号、or 等字符本身无危险，核心是用户输入未被当作纯数据，而是直接拼入 SQL 查询结构，打破数据与指令边界、篡改语法，这才是漏洞根因；若输入仅作为数据隔离，再特殊的字符也无法触发注入。
3. Low 与 Medium 的差异在哪里
防护程度：Low 无任何过滤、转义，输入直接拼接进 SQL 语句；Medium 有基础防护，会转义 / 过滤单引号等特殊字符。
注入难度：Low 可直接用单引号等构造注入语句，易污染查询结构；Medium 常规字符型注入失效，需宽字节、数字型等绕过方式。
核心差异：Low 完全开放查询结构，输入可直接污染语法；Medium 通过字符限制，阻碍输入污染 SQL 查询结构。
4. 普通 SQL 注入与 Blind SQL Injection 的差异在哪里

普通 SQL 注入：有直接回显，可直观看到数据库查询结果、SQL 报错信息，能快速获取库、表、字段等数据，攻击高效。
盲注（Blind SQL Injection）：无直接回显，无明文数据、无报错，仅能通过页面正常 / 异常、响应延迟等状态，逐位猜解数据，攻击繁琐。
共性：二者根因一致，均为输入污染 SQL 查询结构，仅反馈形式不同。
5. 什么盲注和普通注入根因相同，但证据形式不同
根因相同：二者核心根因均为用户输入未被隔离，直接拼入 SQL 查询结构，导致结构被污染，本质都是数据与指令边界混淆，触发 SQL 注入漏洞，漏洞原理完全一致。
证据形式不同：普通 SQL 注入有直接回显，以页面展示的明文数据、SQL 报错信息为攻击证据，可直观获取数据；盲注无直接回显，无明文、无报错，仅以页面正常 / 异常状态、响应延迟为间接证据，需通过状态判断猜解数据，二者仅反馈形式（证据）有区别，根因未变。
强制判断题
1.你必须明确表态并解释理由：
SQL 注入的根因更接近
A. 输入里有几个危险字符
B. 输入进入了不该进入的查询结构
答案：B
理由：特殊字符本身不存在危险性，SQL 注入根本原因是程序未隔离用户输入，将输入直接
2.拼接进 SQL 查询结构，混淆数据与指令边界，造成语句结构被篡改，并非危险字符导致漏洞。
Blind SQL Injection 和普通 SQL 注入的最大差异更接近
A. 根因不同
B. 证据形式不同
答案：B
理由：盲注与普通注入的底层根因完全一致，都是查询结构被恶意污染；二者唯一区别是页面反馈方式，普通注入直接回显数据或报错，盲注依靠页面状态、响应延迟间接判断，仅证据形式不同。
任务 4：SQL 注入防护清单与解释
1. 参数化查询
它解决什么问题：将用户输入固定为纯数据，彻底隔离指令与数据，拒绝输入拼接进 SQL 语句，从源头防止 SQL 结构被篡改。
它控制哪一层：根因控制，直接解决查询结构被污染的核心漏洞。
它不能替代什么：无法替代输入校验、权限管控，不能防御业务逻辑漏洞、越权访问等其他风险。
2. 输入校验
它解决什么问题：对用户输入的长度、格式、字符范围进行限制，过滤非法特殊符号与恶意内容，减少恶意 payload 传入。
它控制哪一层：暴露面控制，缩小可被利用的攻击入口，降低注入触发概率。
它不能替代什么：不能替代参数化查询，仅做校验仍可被特殊绕过，无法杜绝 SQL 语句拼接带来的结构污染。
3. 错误处理
它解决什么问题：关闭数据库详细报错回显，统一使用通用错误页面，避免泄露库名、表名、语句结构等敏感信息。

它控制哪一层：暴露面控制，隐藏漏洞证据与数据库细节，防止攻击者利用报错进一步构造注入语句。
它不能替代什么：无法修复注入漏洞本身，只隐藏攻击线索，不能阻止 SQL 语句被篡改执行。
4. 最小权限
它解决什么问题：限制数据库账号权限，仅分配业务必需的查询、修改权限，禁止使用高权限管理员账号连接业务系统。
它控制哪一层：后果范围控制，即使发生注入漏洞，也能限制数据窃取、删库、提权等高危操作的破坏范围。
它不能替代什么：不能阻止注入攻击发生，只能降低漏洞被利用后的危害程度。
5.可补充其他合理措施
特殊字符转义与过滤：
它解决什么问题：对单引号、双引号、注释符等关键特殊字符进行转义处理，破坏注入语句的闭合与拼接条件。
它控制哪一层：暴露面控制，临时加固输入边界，阻挡基础注入 payload。
它不能替代什么：属于被动防御，存在绕过风险，不能替代参数化查询的根因防护。
七、收口项
收口项 1：SQL 注入因果链/防护关系图

流程环节	**核心行为 / 现象**	**因果关联**	**根因定位**	**对应防护控制点**	**防护作用层级**
输入点	用户提交正常内容或恶意注入载荷	恶意输入为攻击起始条件，无管控则进入后端处理	非根因，仅为攻击入口	输入校验	暴露面控制
查询构造	后端直接拼接用户输入，混入 SQL 语句	输入篡改原有语法，**污染查询结构**，是关键转折	核心根因：数据与指令未隔离	参数化查询	根因控制
数据库解析 / 执行	数据库解析篡改后的 SQL 并执行非法语句	被污染的结构被正常执行，攻击正式生效	根因直接引发执行异常	特殊字符转义	暴露面控制
结果差异 / 行为证据	数据泄露、语法报错、页面真假状态、延迟响应	执行异常产生差异化回显，成为攻击证据	漏洞利用的外在表现	统一错误处理	暴露面控制
后果影响	批量脱库、恶意删改数据、权限越权	注入成功后造成各类安全损害	漏洞带来的延伸危害	数据库最小权限	后果范围控制

收口项 2：学生自评表
1.我本章最清楚的一点是什么？

能够完整掌握 SQL 注入完整因果链，明白输入拼接导致查询结构污染是核心根因，同时可以清晰区分 DVWA 中 Low 与 Medium 级别的防护差异，理解普通注入和盲注的外在区别。
2.我最容易混淆的一点是什么？
容易混淆各类防护措施的控制层级，分不清参数化查询、错误处理、最小权限分别属于根因控制、暴露面控制还是后果控制，容易把所有防护措施笼统归为同一类。
3.我本次作业中哪一段最需要教师复核？
任务 4 防护清单部分，对于每种防护措施 “解决问题”” 和 “控制层级” 的对应表述，担心划分不够准确，需要老师核对分层逻辑是否正确。
4. 如果重做一次，我会优先改哪一部分？
优先完善收口项因果关系表，强化流程之间的因果联系，不只是罗列环节，让攻击链路和防护阻断的对应关系更直观、逻辑更严密。
收口项 3：AI 输出审核与人工复核记录（必做）
1.本作业哪些内容使用过 AI 辅助
本次作业中，SQL 注入各任务的基础框架、概念定义和一些基础原理表达、因果关系表格整理等内容，使用了 AI 辅助排版与文字优化。
2.哪些判断是你自己复核后保留的
所有选择题答案、漏洞根因判断、Low 与 Medium 差异区分、普通注入与盲注核心区别、防护措施分层判定（根因控制、暴露面控制、后果范围控制）等是由复核后确认保留。
3. 哪些内容你发现 AI 输出不准确并进行了修正
一些概念基础原理表达不够通顺以及一些概念会模糊处理
4.你最终如何确认结论和证据是一一对应的
以课堂讲解核心结论和讲义内容为标准
十、提交前自查清单
提交前逐项核对：
我是否只在授权环境中完成实验 是
我的截图是否已脱敏 是
我是否说明了“正常查询变化”和“查询逻辑被改变”的区别 是
我是否把根因写成“结构被污染”，而不是只写“特殊字符” 是
我是否区分了普通 SQL 注入与盲注的证据差异 是
我是否把参数化查询、错误处理、最小权限放回不同控制层 是
我是否完成了关系图/关系表 是
我是否填写了 AI 输出审核与人工复核记录 是